



Reactions

What other people have said publicly about the Coldcard vulnerability — quoted in full and captured here, whether or not it is still up, in case it does not stay that way.

These are other people's words, reproduced so they stay findable. Quoting a post here is not a claim that it is accurate — every entry links to the original so you can read it in context and judge for yourself.

[Newest first](#)[Oldest first](#)

Leo Wandersleb @LeoWandersleb  12 Aug 2021

I'm analyzing @COLDCARDwallet Mk3 for @WalletScrutiny and can't find any claims about the sources of entropy. Does the device by default rely solely on randomness from its "secure element" for masterseed creation?

Pointers to firmware code or claims would be awesome!

This looks like the default is to use only the TRNG. RNGs are close to impossible to verify if they produce true randomness.

Whitening helps a bit against very specific attacks but not against the provider knowing the random numbers.

Join Nostr

@LeoWandersleb

I'm analyzing @COLD CARDwallet Mk3 for @WalletScrutiny and can't find any claims about the sources of entropy. Does the device by default rely solely on randomness from its "secure element" for masterseed creation?

Pointers to firmware code or claims would be awesome!

9:49 PM · Aug 12, 2021

2

4

5

1

Relevant ▾View activity >

Post your reply

Reply

Miha

@MihaelSmrekar · Sep 25, 2021

They have something about this at the bottom of their faq: coldcardwallet.com/docs/faq

1

Join Nostr

@LeoWandersleb · Sep 25, 2021

This looks like the default is to use only the TRNG. RNGs are close to impossible to verify if they produce true randomness.

Whitening helps a bit against very specific attacks but not against the provider knowing the random numbers.

COLD CARD

User Docs

FAQ

Sections ▾

Where does the entropy (randomness) come from?

It's very important the entropy (randomness) used to pick your master seed phrase is good quality. The Coldcard uses the hardware TRNG (True Random Number Generator) inside the main chip. This is a dedicated hardware subsystem that measures analog noise produced by a special transistor. We do not use the TRNG present in the secure element because we do not want to expose the number to external probing.

The number from the TRNG is then "whitened" to remove bias, by running it through SHA256. This means if your attacker was somehow able to make the bits be 10% ones and 90% zeros (but still random otherwise) it would not help them, because after SHA256 the bit distribution will be 50/50 again.

During seed picking process, you have the option of "adding dice rolls" to increase the entropy and/or mitigate any possible manipulation. You can add as many rolls as you wish, and the entropy (about 2.5 bits per roll) will be added to the 256 bits of entropy already picked.

You may completely bypass the above seed picking method, and use purely dice rolls if desired. This process is documented in great depth [here on our docs](#) and includes a number of different ways to verify our SHA256 math for yourself. We even sell a [package of 100 tiny dice](#) so you can roll 256 bits of your own entropy in a single toss.

1

2

Wandersleb runs WalletScrutiny, which reviews hardware wallets. He asked in August 2021 where the Coldcard Mk3 gets its entropy; the two replies the thread shows are another user pointing him at the FAQ and his own conclusion from reading it, six weeks later. Neither is from Coldcard. The FAQ section in his screenshot is the same one NVK had posted approvingly on 8 September 2021, filed under Receipts.

REFERENCED IN THE POST

Coldcard's FAQ, the page he was pointed to [↗](#)
WalletScrutiny's Coldcard Mk3 review [↗](#)

Via Leo Wandersleb on Nostr

Open the post [↗](#)

Economy-Cash6726 u/Economy-Cash6726 Reddit

Ordered Coldcard Mk4 and wallet got drained even though I used a 12 word seed with no dice rolls. Ledger is better device and less cost

Yes when it happened with me and I reported it I was blocked on their channel. They did not acknowledge the issue and several others encountered same. I even asked for refund from hodldee on Reddit and he still denied to pay me what I paid for the hardware wallet

 Economy-Cash6726 2y

Ordered Coldcard Mk4 and wallet got drained even though I used a 12 word seed with no dice rolls. Ledger is better device and less cost

     8 



Inevitable-Waltz-889 1d

When did this happen?!

     1 



Economy-Cash6726 1d

2022

     4 



Inevitable-Waltz-889 1d

Damn. Did you hear about what just happened to a ton of ColdCard users?

     1 



Economy-Cash6726 1d

Yes when it happened with me and I reported it I was blocked on their channel. They did not acknowledge the issue and several others encountered same. I even asked for refund from hodldee on Reddit and he still denied to pay me what I paid for the hardware wallet

     8 

Both quotes are the same person. The first comment sat in an r/ledgerwallet thread for two years; the second is their answer when another user asked about it in the days after the vulnerability became public. Asked when the wallet was drained, they say 2022.

REFERENCED IN THE POST

The r/Bitcoin thread that resurfaced it [↗](#)

Ali Sherief (@ZenuL_Abidin) on X, where this screenshot circulated [↗](#)

[Read the original](#) [↗](#)